

LAB GUIDELINES

Lab 22 — Auditing, Logging, and SIEM Basics

Maps to CompTIA Server+ objective **3.4 — Explain data security risks and mitigation strategies** (mitigation strategies: data monitoring; log analysis — security information and event management (SIEM); two-person integrity, separation of roles) and ties back to **2.3** (event logs, retention, rotation, shipping).

Run all commands on <https://killercode.com/playgrounds/scenario/ubuntu>

Required software (free, apt): auditd, rsyslog, logwatch

```
apt update && apt install -y auditd audispd-plugins rsyslog logwatch
systemctl enable --now auditd rsyslog
```

Step 1 — auditd: watch sensitive files

Server+ 3.3 audit targets: user activity, logins, group memberships, deletions. Write rules for each:

```
cat > /etc/audit/rules.d/99-server-plus.rules <<'EOF'
# user / group changes
-w /etc/passwd -p wa -k id_changes
-w /etc/shadow -p wa -k id_changes
-w /etc/group -p wa -k id_changes
-w /etc/sudoers -p wa -k privesc
-w /etc/sudoers.d/ -p wa -k privesc

# logins (consumed via pam_tty_audit)
-w /var/log/wtmp -p wa -k logins
-w /var/log/btmp -p wa -k logins

# deletions in important dirs
-a always,exit -F arch=b64 -S unlink,unlinkat,rename,renameat -F dir=/etc -k file_delete
-a always,exit -F arch=b64 -S unlink,unlinkat,rename,renameat -F dir=/var/log -k file_delete
EOF
augenrules --load
auditctl -l | head
```

Trigger and view:

```
useradd dummy
groupmod -n dummy2 dummy 2>/dev/null
ausearch -k id_changes -ts recent | tail -20
```

Step 2 — rsyslog: severity levels and forwarding

Severity levels (memorise — the SIEM ingest filters on them):

Level	Name	Use
0	emerg	System unusable
1	alert	Immediate action
2	crit	Critical failure
3	err	Error
4	warning	Warning
5	notice	Normal but significant
6	info	Informational
7	debug	Debug

```
logger -p auth.notice "Server+ lab test: notice-level entry"
```

```
tail -1 /var/log/syslog
```

Forward to a central collector (production: TCP for reliability):

```
cat > /etc/rsyslog.d/90-forward.conf <<'EOF'
*. * @siem.lab.local:6514      # @@ = TCP, single @ = UDP
EOF
# systemctl restart rsyslog    # don't enable on Killercode; no receiver
```

Step 3 — Log rotation and retention

```
cat > /etc/logrotate.d/srvplus <<'EOF'
/var/log/syslog
/var/log/auth.log
{
    weekly
    rotate 12      # keep 12 weeks → ~90 days
    compress
    delaycompress
    missingok
    notifempty
    create 0640 syslog adm
}
EOF
logrotate -d /etc/logrotate.d/srvplus 2>&1 | tail
```

Retention must match the policy from Lab 17 (compliance, legal hold).

Step 4 — Daily report with `logwatch`

```
logwatch --output stdout --range today --detail Med | head -60
```

Logwatch summarises sshd / sudo / cron / disk / mail in one report you can email nightly.

Step 5 — SIEM concept (Server+ 3.4)

A SIEM (Wazuh, Graylog, Splunk, Elastic) does five things — practise the workflow on the local log set:

1. **Collect** — agents or rsyslog forwarders ship logs.
2. **Normalise** — parse into a common schema (e.g. CEF, ECS).
3. **Correlate** — rules look for sequences ("5 failed logins → 1 success" = suspicious).
4. **Alert** — fire on rule match.
5. **Investigate** — pivot on user / host / time across all sources.

Simulate a correlation rule with grep:

```
# 5+ failed sshd attempts followed by an Accepted from the same IP
awk '/sshd.*Failed/ {fails[$NF]++} /sshd.*Accepted/ {if (fails[$NF]>=5) print "ALERT: brute then su"}
```

Step 6 — Two-person integrity & separation of roles

Server+ 3.4 names these explicitly:

- **Two-person integrity (TPI)**: critical operations require *two* people present. Example: vaulting backup tapes, opening the off-site safe, applying a database root password change.
- **Separation of roles (= duties)**: the person who *requests* a change is not the person who *approves* it is not the person who *implements* it. Built into the sudoers split in Lab 20 and the change-management form in Lab 17.

Split-key example with ssh-keygen + gpg:

```
ssh-keygen -t ed25519 -N '' -f /tmp/root_emergency_key -C "emergency root"
# In production: split the private key into two halves with gpg --split-secret, give one half to ea
ls /tmp/root_emergency_key*
```

Step 7 — Tie it together: an alert pipeline you can build

auditd / rsyslog → forwarder → SIEM (Wazuh) → correlation rule → email + ticket

■

■■■ retention: 90 days hot, 1 year cold

■

■■■ runbook for response (Lab 28)

Free online tools

- **Wazuh (free SIEM)** — <https://wazuh.com/>
- **Graylog Open** — <https://graylog.org/>
- **Elastic Stack** — <https://www.elastic.co/elastic-stack>
- **MITRE ATT&CK** — <https://attack.mitre.org/>

What you learned

- auditd rules covering the four audit targets named in objective 3.3.
- rsyslog severity levels and TCP/UDP forwarding to a collector.
- Log rotation + retention aligned to policy.
- Daily `logwatch` summary for ops review.
- The five SIEM workflow stages and a simple correlation example with awk.
- Two-person integrity and separation-of-roles mechanics from Server+ 3.4.